“Informational” + “Low” + “Medium” = Critical

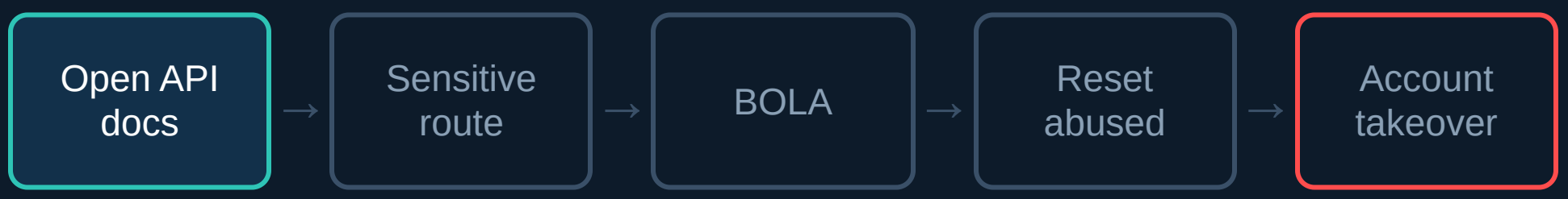
How a public API doc becomes an account takeover. The chain, and the fix at every step.

Exposed API docs

Unauthenticated Swagger/OpenAPI lists every route, parameter and role.

One engagement: **~190 endpoints** exposed.

> Fix: require auth, or disable docs in production.

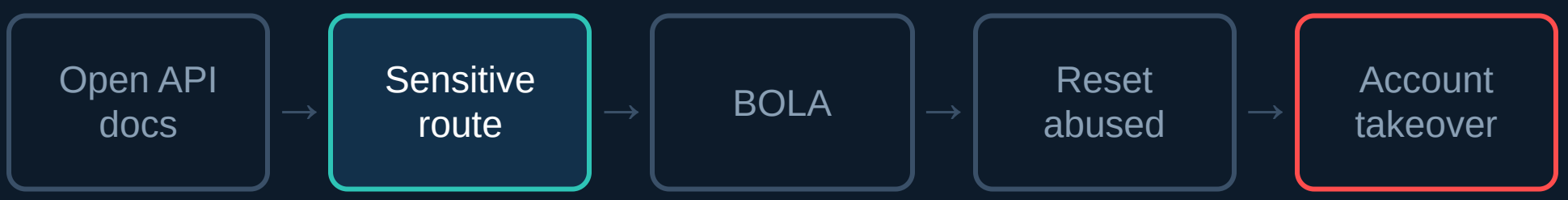


STEP 2

Find the sensitive routes

Password reset, profile, admin helpers: easy to spot when the docs name them.

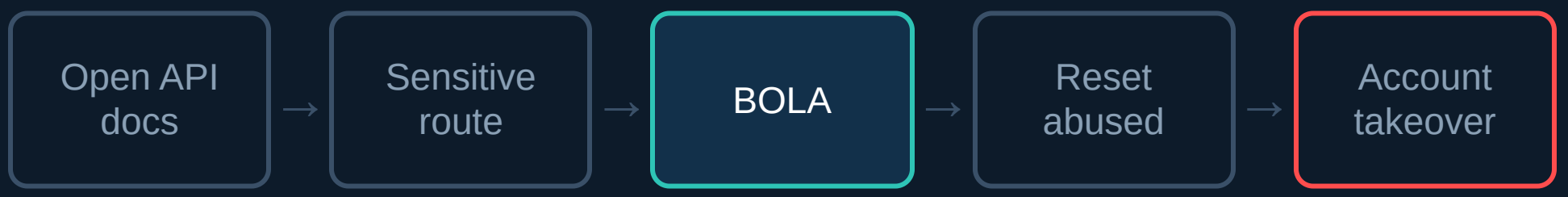
> Fix: no security by obscurity. Every route needs its own authorization.



Broken object-level authorization

An ID in the request is trusted without checking who owns the object.

> Fix: server-side ownership check on every object access.

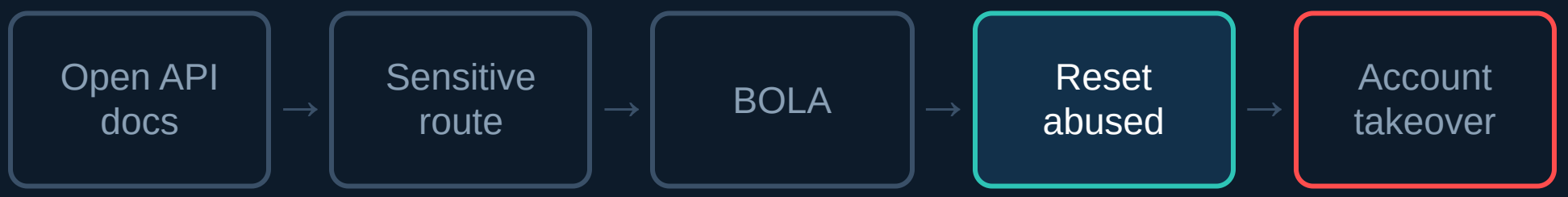


STEP 4

Weak reset / verification flow

No rate limits or weak tokens turn data access into account control.

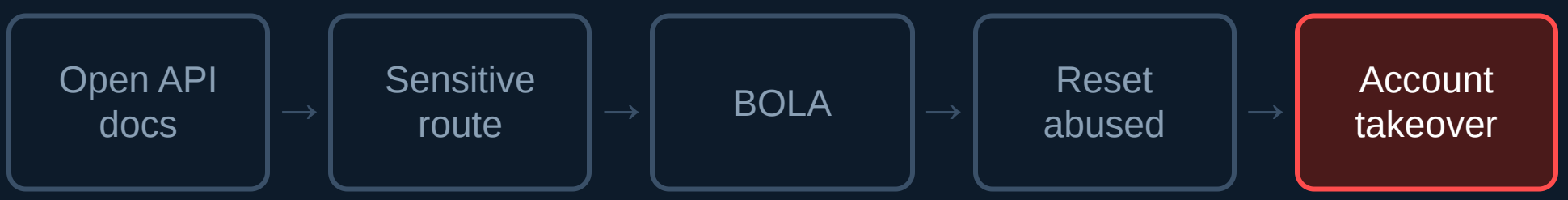
> Fix: rate limiting, single-use short-lived tokens, notify the user.



Account takeover

Low-severity findings, chained, end in full account control.

On real work I independently confirmed **2 CRITICAL** account-takeover chains.



Score the chain, not the line item

- Hide the map **and** lock the doors
- Retest after the fix: risk score dropped ~80% / ~75% after remediation
- A finding isn't closed until the chain stops working

YOUR TURN

Which step does your team check least?

Drop it in the comments 👇

Sohaib Gamal · Security QA Engineer & Penetration Tester
Web / API / business-logic security